

MRK18 · STRATEGY BRIEF

Production-Readiness & Investor-Ready Plan

A scoped path to ship a credible product for ~10 design-partner customers and raise a round — plus the full at-scale readiness analysis as an appendix.

Prepared 23 June 2026 · AI-CMO ("CMO in your pocket") · RunPod Serverless + Supabase + FastAPI/LangGraph + Next.js

MRK18 — Investor-Ready with 10 Users (scoped production plan)

Goal (set 2026-06-23): make the webapp production-ready for ~10 customers to become **investor-ready**, raise a round, then build traction. NOT a public launch at scale. Already on **RunPod Serverless** (scale-to-zero); **Supabase Pro** covers the whole data layer. Reframe: at 10 hand-held users the risk is **embarrassing the demo** or a **diligence landmine** — not load. Build only what serves those two. The bar investors hold at this stage: *it works reliably, the insight is real (not mock), there's a retention signal, some users PAY, and diligence finds no landmine.* ~2–3 weeks of focused work + legal in parallel.

Phase 1 — Trust & safety core *(don't lose a user or leak data)* — ~week 1

1. **Tenant isolation.** Verify EVERY Supabase query in the FastAPI backend is scoped to the user/tenant; enable **RLS** on every public-schema table as a safety net; add **one automated cross-tenant read test** in CI. *(Single highest must-do — one cross-tenant leak in a demo ends it.)*
2. **Idempotency on side effects.** A retry/refresh must not double-publish, double-charge cost, or double-write. Add an idempotency check (`run_id+node`) **before** every side-effectful node (publish, cost metering, Supabase writes, paid Tavily/LLM calls). No Celery needed at 10 users — just "did I already do this?".
3. **Gates hard + no invented numbers.** Keep Gate-1 (strategy) and Gate-2 (per-post) human approvals mandatory. Any metric shown must come from a **real API value**, never the LLM. One hallucinated "your CAC is ₹X" kills the "real CMO" pitch.
4. **Graceful failure UI.** Clean error states everywhere (the run "failed" path, network errors) — no white screens. Demos hit edge cases.
5. **Secret/endpoint hygiene.** Run **Gitleaks** once (rotate anything found); vLLM/RunPod endpoint **not** publicly exposed; `service_role` /RunPod keys server-side only.

Phase 2 — Make it real & make it pay *(the moat + revenue signal)* — ~week 1–2

1. **One real connector live.** Replace `web/lib/mock/` with a real **Stripe read-only** (fastest) or **GA4** connector for at least 3–5 of the 10; clearly label live-vs-simulated. *Real insight on real data is worth more than everything else combined in a fundraising demo.*
2. **Monetization.** Wire **Razorpay** (India) or Stripe Billing so some of the 10 actually **pay** (even ₹999/mo). "Paying customers" is the #1 pre-seed traction signal.
3. **Light adapter sanity-check.** Before promoting the 4 in-training adapters into the demo path: a small golden set (~30 prompts/role), eyeball quality, keep the prior version for rollback. (Full eval/canary infra is post-funding — this is the cheap version.)
4. **Onboarding / activation.** Make sign-up → company-brain form → first successful campaign fast and smooth. No activation = no retention to show.

Phase 3 — Reliability & the traction story *(the demo works + you can prove it)* — ~week 2

1. **1 warm RunPod worker** during demo/business hours so a cold start never makes it look broken.
2. **Uptime monitor + alert** (UptimeRobot / BetterStack free) on the app + API + GPU endpoint.
3. **Come-back loop.** Email (or WhatsApp) notification when a run needs approval or is done. Drives return visits = your retention metric.
4. **Product analytics** (PostHog free tier): activation, repeat usage, week-over-week retention — this generates your pitch-deck numbers.

5. **Seeded demo tenant.** A clean tenant with real-looking data so the investor walkthrough never depends on a live cold run.

Phase 4 — Diligence pack ***(no landmines)*** — parallel / light

1. **Legal & IP** *(biggest non-technical landmine)*: company incorporated; the **9 adapter weights + the code IP assigned to the company**; founder/contributor IP-assignment agreements. If the weights aren't owned by the entity, it's a deal-killer.
 2. **Privacy policy + terms** (a generated template is fine to start).
 3. **Account deletion + data export** (cheap DPDP/diligence hygiene).
 4. **Don't train adapters on customer data without explicit, revocable consent** — and audit the 5 trained adapters for any PII baked in.
 5. **Backups verified** (Supabase Pro daily backups + one tested restore) + a one-page architecture/security note for the technical advisor.
-

Explicitly **OUT of scope until post-funding (do NOT build yet)**

Kubernetes · multi-region · autoscaling beyond serverless · SOC 2 · full DPDP/CERT-In apparatus · adapter canary/shadow/registry machinery · per-user billing ceilings · heavy observability stacks · the pocket hardware device. All premature at 10 users — wasted motion and money.

The fastest two to start

(1) Phase 1 tenant-isolation pass (RLS + scope audit + cross-tenant test) and **(2) Phase 2 Stripe read-only connector** replacing the mock. The first is the cheapest insurance against the worst demo outcome; the second is what turns the pitch from "wrapper" to "real product."

MRK18 — Production-Readiness Plan & Risk Register

Synthesized from a 6-lens multi-agent web-research sweep (model serving/LoRAOps, agent reliability, infra & unit economics, India security/compliance, GTM/competition, data-integrations/trust). Date: 2026-06-23.

Verdict

NOT production-ready, and not close — but fixable on a focused 3–4 month path.

The product today is a content-generation tool on a **mock analytics shell**, served by an **ungated, un-failed-over brain**, with **unit economics that are negative at current scale**, and a **live (not future) India compliance gap**. Do **not** do a public launch in this state.

Honest status: *"promising private-beta candidate, ~60–90 days of hardening away from charging money safely."*

Three non-negotiables before ANY paid user touches it:

1. An adapter **eval + rollback gate**.
2. An inline **grounding / brand-safety guardrail** (with the two human gates kept hard).
3. **CERT-In logging + RunPod failover + idempotent side-effects**.

Two strategic calls to make now:

- **Kill or indefinitely defer the pocket hardware device** — reframe "CMO in your pocket" as a PWA.
- **Ship the GA4/Ads/Stripe connectors before spending more on adapters** — connected data is the

only thing that turns this from a commoditizable wrapper into a defensible vertical agent.

Top blockers (ranked by severity × likelihood)

#	Blocker	Area	Sev	Likelihood
1	No adapter eval/release gate — 5 LoRA adapters already serve paying founders, 4 about to ship blind (no golden-set evals, regression check, canary, or rollback)	Model serving / LoRAOps	critical	high
2	No inline grounding/brand-safety guardrail on auto-generated public copy that will soon quote real GA4/Stripe/ad numbers	Output quality / trust	critical	high
3	Single RunPod GPU host = SPOF , no failover, fixed GPU floor (~\$570–1,000+/mo) breaks unit economics below ~50–60 users	Infra / cost / reliability	high	high
4	LangGraph durability/idempotency gaps — crash/double-resume can double-publish, double-charge, or strand runs; stuck gates with no notify/TTL/audit	Agent reliability	high	high
5	Live India compliance gap — CERT-In (6-hr reporting, 180-day India-resident logs, NTP, criminal liability) in force NOW and unmet; DPDP lands by May 2027	Security / compliance	high	medium
6	Connectors (GA4/Ads/Stripe) not live — analytics runs on mocks, so the actual moat doesn't exist; platform API approvals take months	GTM / moat	high	high
7	Pocket hardware device on roadmap — 85% of 2025 AI-hardware startups failed; capex/supply-chain/support would starve the software core	Strategy / roadmap	high	medium
8	Exposed/unhardened vLLM endpoint + Supabase RLS/secrets risk — leaks customer data AND the 9-adapter IP	Security / infra	high	medium
9	Multi-LoRA throughput penalty + per-run fan-out can blow past the ₹50 cap and latency budget; cold-adapter swaps cause erratic latency	Model serving / perf	medium	medium
10	Low-ARPU SMB churn — ₹1–2k/mo, low switching cost, ~8%/mo churn, ~18% UPI Autopay cancellation destroys LTV	GTM / unit economics	medium	high

Mitigations (per blocker)

- Eval gate:** per-role versioned golden set (50–200 prompts) + LLM-as-judge rubric + capability-regression check (reject >2–3 pt MMLU-class drop) + brand-safety pass. Shadow → canary on live traffic → full rollout. Keep prior good version hot for one-command rollback. Build BEFORE promoting the 4 in-training adapters; re-validate the 5 live ones.
- Guardrail:** forbid the model from generating numbers — bind every figure to a real API value with visible provenance; groundedness/citation check; brand-safety classifier (Llama-Guard-class) on all public copy; structured-output conformance before publish. Keep Gate-2 hard; surface flags at the gate. Low temperature on analytic adapters.
- Infra:** keep the vLLM+LoRA image portable; warm-startable second provider/region (Modal/Baseten/India host) + documented degraded mode. Below ~50 users → scale-to-zero serverless (min-1 warm worker in India business hours); always-on only past the ~25% utilization break-even. Instrument **cost-per-active-customer** and **active-users-per-GPU** as the #1 business KPI.
- Durability:** idempotency key (`run_id+node+attempt`) + check-before-commit on every side-effectful node (publish, Supabase writes, cost metering, paid Tavily/LLM calls); Postgres advisory lock on `thread_id` before any resume; move multi-minute runs to a durable queue (Celery/RQ/Arq+Redis or RunPod async) — never FastAPI BackgroundTasks; on interrupt → notify + TTL sweeper + exportable approval audit log.
- Compliance now:** India-resident 180-day ICT logging, NTP clock-sync, named incident responder, 6-hr CERT-In runbook (also satisfies DPDP 72-hr). Confirm each vendor's log-storage region. Before connectors: consent capture, sub-processor DPAs, retention/deletion flows.
- Connectors:** start ALL platform approvals immediately and in parallel; minimize OAuth scopes (top rejection cause). Ship Stripe read-only + GA4 first; be honest in-product about live vs simulated. Decide unified-API/iPaaS vs in-house BEFORE writing per-connector code.
- Hardware:** kill/defer; reframe as PWA. Revisit only after software is retained, profitable, and demonstrably demanded on a device.

8. **Security:** never expose vLLM directly — reverse proxy + IP allowlist + segmentation, patch, firewall non- /v1 + ZeroMQ. RLS on every Supabase table + cross-tenant CI test; `service_role` server-side only. Secrets → managed store + rotation; Gitleaks pre-commit + CI.
 9. **Perf:** tune `max_loras` to real concurrency, `max_lora_rank` to actual max rank; pin all 9 adapters hot + pre-warm; batch same-adapter requests; benchmark p50/p95 with a realistic 9-adapter mix.
 10. **Retention:** ship connectors fast; annual UPI Autopay (20% off) + smart-retry on failed debits; gate dedicated-GPU capacity to retained cohorts; track activation→week-4→week-12 + per-customer edit-rate as the churn signal.
-

Requirements by area (must-have = P0)

Model serving & LoRAOps

- **Must:** eval+release gate in CI; adapter registry w/ full lineage + one-command rollback; pin `(prompt, adapter, base)` per run; shadow+canary every promotion.
- **Should:** per-adapter drift/quality monitoring (weekly canary + KL/PSI + guardrail-trip rate); tuned multi-LoRA vLLM config benchmarked under realistic mix; `merge_and_unload` hottest adapter to a dedicated endpoint if swap cost dominates.

Output quality, guardrails & trust

- **Must:** inline grounding (no model-generated numbers; bind to API values w/ provenance); brand-safety classifier + structured-output conformance before publish; keep Gate-1/Gate-2 hard with flags surfaced; low temp + PII scrub on analytic adapters.
- **Should:** per-customer brand-voice profile + consistency scoring; edit-rate as a KPI; cross-source reconciliation (GA4 vs Ads vs Stripe) with honest "sampled/estimated" labels.

Agent reliability, durability & observability

- **Must:** idempotency key + check-before-commit on side-effectful nodes; distributed lock on `thread_id` before resume; durable job queue for multi-minute runs (return `job_id`, poll/stream); stuck-interrupt lifecycle (notify + TTL + audit log); strict JSON-Schema + constrained decoding at every agent boundary with bounded retries.
- **Should:** trace-first observability (OTel/LangSmith/Langfuse) across the run tree; online LLM-judge + brand-safety on sampled traffic feeding the golden set; health checks/timeouts/circuit breakers around vLLM.

Infrastructure, cost & scaling

- **Must:** eliminate single-GPU SPOF (portable image + warm second region + degraded mode); honest GPU cost-floor model; cost-per-active-customer + active-users-per-GPU dashboards; per-user/month token+cost ceiling per tier; secrets management + Gitleaks.
- **Should:** Supabase Pro + Supervisor pooler + PITR w/ tested restore; uptime/alerting on GPU+API+DB; CI/CD with staged, gated migrations on a separate staging project.

Security, privacy & compliance (India-first)

- **Must:** CERT-In now (India-resident 180-day logs, NTP, incident responder, 6-hr runbook); harden vLLM (never internet-exposed); RLS on every Supabase table + cross-tenant CI test; no training on customer data without explicit revocable consent + audit the 5 trained adapters for PII; treat all Tavily/web content as untrusted (least-privilege tools, outbound-URL allowlist, publish never invokable from model output alone).
- **Should:** DPDP consent/notice/rights/retention/grievance layer ahead of May 2027; Clerk hardening (admin MFA, bot protection, short-lived JWTs, HttpOnly cookies); SOC 2 trajectory (Type I first); GDPR geo-scope decision.

Data integrations & publishing

- **Must:** decide iPaaS vs in-house before per-connector code; start ALL approvals in parallel; ship Stripe read-only + GA4 first + label live-vs-simulated; official approved APIs only (LinkedIn Community Mgmt, Meta/IG Content Publishing, X) respecting caps; robust OAuth lifecycle (refresh rotation, scope minimization, revocation, re-auth UX).

- **Should:** X-API cost-aware scheduler; **WhatsApp Business / click-to-WhatsApp as a first-class India channel**; IAB-aligned AI-content disclosure.

GTM, pricing & roadmap strategy

- **Must:** kill/defer the hardware device (→ PWA); sequence connectors BEFORE further adapter spend; instrument per-account gross margin; one-sentence defensible moat thesis (connected-data leak detection + India context).
 - **Should:** flat predictable ₹ pricing; assisted/community/referral India SMB distribution; annual UPI Autopay + smart-retry + cohort tracking; consider content-only entry tier; continuous blind benchmark vs frontier models.
-

Phased roadmap

Phase 0 — Harden the core (weeks 0–6, pre-any-paid-user)

Make the brain safe to ship and the platform safe to run.

- Adapter eval+release gate in CI; re-validate 5 live; do NOT promote the 4 until they clear.
- Adapter registry + one-command rollback; pin (prompt, adapter, base) per run.
- Inline grounding + brand-safety guardrail; forbid model-generated numbers; Gates hard.
- Idempotency + thread_id resume lock on every side-effectful node.
- Durable job queue; stuck-interrupt notify+TTL+audit.
- CERT-In baseline (India logs, NTP, responder, runbook).
- Harden vLLM; Supabase RLS + cross-tenant CI test; secrets store + Gitleaks.
- Tracing/observability + cost-per-active-customer / active-users-per-GPU dashboards.
- **DECISION: kill/defer hardware → PWA.**

Phase 1 — Private beta (weeks 6–12)

Prove real value on real data with a small hand-held cohort.

- Ship Stripe read-only + GA4 live; label live-vs-simulated; start other approvals in parallel.
- RunPod failover + degraded mode; scale-to-zero w/ warm India-hours worker; tune 9-adapter config.
- Shadow+canary the 4 newly-gated adapters.
- Instrument per-account gross margin + per-user monthly ceilings; validate ₹1–2k survives a power user.
- Recruit 20–50 founders via community/referral; track activation→week-4, edit-rate, per-customer margin.
- DPDP consent/retention/deletion + sub-processor DPAs; begin SOC 2 Type I.

Phase 2 — Public launch (months 3–5)

Open up only once retention, reliability, margin, and moat are proven.

- Harden official-API publishing (LinkedIn/Meta/IG/X) + draft+manual fallback; add WhatsApp.
- Ship Ads connectors once approved; cross-source reconciliation + honest labeling.
- Per-adapter drift monitoring w/ auto re-gate; online LLM-judge feeding the golden set.
- Finalize flat ₹ pricing + annual UPI Autopay; possibly content-only + analytics tiers.
- Lock the moat thesis and align marketing to it.

Phase 3 — Scale (months 5+)

- Always-on/dedicated GPU only past sustained break-even; pack 100+ founders/GPU before adding a second.
 - Multi-region/India inference for sensitive connector data; SOC 2 Type II.
 - Complete DPDP readiness (Consent Manager) ahead of May 2027.
 - Continuous frontier-vs-fine-tuned benchmarking; route hard low-volume tasks to a frontier API.
 - Revisit hardware ONLY if software is retained, profitable, and the device beats a phone.
-

Unit-economics reality check

Per-run variable cost is NOT the threat. A full pipeline run (Tavily advanced ~₹4 + ~180k tokens self-hosted, amortized) is roughly **₹12** — comfortably under the ₹50 cap. Even a 40-runs/month power user spends ~32% of a ₹1,500 ARPU on variable cost.

The killer is the FIXED GPU floor, which the ₹50/run and daily caps do not touch:

- Always-on L40S ≈ **\$570/mo**; A100 80GB ≈ **\$850–1,000+/mo** — whether or not anyone runs a job.
- At ~₹1,500 ARPU (~\$17.4) you need **~57 paying subscribers just to break even on ONE GPU**.
- The GPU only gets cheap per head at **100–200 active founders** sharing it (~₹430–860/founder).
- Below ~50–60 active users on a dedicated GPU, **gross margin is deeply negative** — *margin death by

idle GPU*, invisible because per-run `cost_inr` looks fine.

Compounding: AI-app gross margins run 40–60% (vs SaaS 70–90%); a single heavy user can go cost-negative without a per-user ceiling; the "token treadmill" silently erodes margin; ~8%/mo SMB churn + ~18% UPI Autopay cancellation can mean the cohort leaves before its GPU is amortized.

Verdict: the price CAN cover cost, but only at sustained utilization. Mandatory: (1) scale-to-zero serverless below ~50 users, always-on only past ~25% utilization; (2) instrument cost-per-active-customer + active-users-per-GPU; (3) per-user monthly ceilings; (4) gate dedicated GPU to retained cohorts; (5) push annual UPI Autopay.

Open questions for the founder (answer these — they change the plan)

1. Are any of the 5 trained / 4 in-training adapters fine-tuned on **REAL founder/customer data**? If yes → membership-inference + DPDP-erasure liability baked into weights. Audit provenance per adapter now.
2. **What is current active-user count and concurrency?** This single number decides serverless vs dedicated GPU and whether unit economics are currently positive or negative.
3. **Where are prompts/outputs (and soon connector data) actually processed/stored** — which RunPod region, Supabase region, third-party judge/guardrail APIs? Needed to close CERT-In residency + DPDP cross-border gaps.
4. Is the **hardware device** a real funded commitment or an aspiration? (Recommendation: kill/defer — confirm no investor/partner promise blocks that.)
5. **Real per-run agent fan-out — which adapters fire per run?** Needed to tune `max_loras` / `max_lora_rank` and confirm the ₹50 cap holds at p95.
6. **iPaaS (Supermetrics/Improvado/Paragon) vs in-house connectors** — which can the team actually maintain? ~7 connectors at 15–25%/yr will consume engineering.
7. Target **gross-margin floor** and the **price ceiling** the India SMB buyer tolerates? Decides whether a content-only + analytics tier split is needed.
8. Has any adapter/prompt change **shipped to prod without a recorded version**? If so, current regressions may already be un-diagnosable — establish the registry + per-run pinning first.
9. **Publishing approval status** with LinkedIn/Meta/IG/X today? If not started, "publish for you" is a quarter away and the launch sequence must reflect that.
10. Is **WhatsApp** on the roadmap? For India SMBs it's the dominant channel (95%+ open rates); shipping only Western social may misread the market.